Security Log Analyzer - pruvodni zprava

Semestralni projekt BI-PYT | Python CLI a lokalni webova utilita pro analyzu autentizacnich logu

1. Reseny problem

Projekt resi analyzu autentizacnich logu a hledani podezrele aktivity. Cilem nebylo vytvorit pouze filtr na text 'Failed password', ale mensi bezpecnostni nastroj, ktery umi logy parsovat, pracovat s casem, seskupovat udalosti do incidentu, priradit riziko a pripravit vystup pro uzivatele nebo analytika.

Vstupem je soubor s logy. Vystupem muze byt textovy report, JSON report, samostatny HTML dashboard, PNG grafy nebo lokalni webove rozhrani bez externiho serveru.

2. Architektura projektu

Kod je rozdelen do samostatnych modulu. Parser prevadi radky logu na LogEvent objekty. Rules obsahuji detekcni pravidla. Incidents prevadi nalezy pravidel na SecurityIncident objekty. Campaigns koreluji incidenty do vyssich celku. Risk pocita skore a severity. Statistics, timeline a enrichment pripravuji souhrny, casove rady a profily IP adres. Report, dashboard, visualization a webapp resi vystupy.

Toto rozdeleni zjednodusuje testovani i obhajobu: kazda cast ma jasnou odpovednost a hlavni skript pouze propojuje hotove funkce pres CLI.

3. Parser a datovy model

Parser podporuje tri typy vstupu: jednoduchy ISO format ze zadani, Linux/OpenSSH syslog radky a key-value radky z aplikacnich logu. Kazda platna radka se prevede na strukturovanou udalost s casem, IP adresou, uzivatelskym jmenem, typem udalosti, puvodnim radkem, cislem radku, formatem zdroje, sluzbou a autentizacni metodou.

Neplatne radky nejsou chyba cele analyzy. Program je preskoci a ulozi diagnostiku, aby bylo videt, kolik vstupu nebylo mozne zpracovat.

4. Detekcni pravidla

Pravidlo	Co hleda	Proc je dulezite
Brute force z IP	Mnoho neuspesnych prihlaseni z jedne IP v kratkem okne	Typicky pokus o hadani hesla
User enumeration	Jedna IP zkousi mnoho uzivatelu	Utocnik muze hledat existujici ucty
Success after failures	Uspesne prihlaseni po serii neuspechu	Silny signal mozne kompromitace
Distributed user attack	Jeden uzivatel je napadan z vice IP	Obchazi jednoduche limity podle IP
Account takeover signal	Uspesny login po neuspesich z vice IP	Korelace mezi distribuovanym tlakem a uspesnym vstupem
Low-and-slow	Opakovane neuspechy rozlozene v case	Nenapadne utoky nemusi prekrocit kratke okno

5. Risk score a severity

Risk score je heuristicke cislo 0-100 pro razeni incidentu podle nal?havosti. Neni to presna pravdepodobnost kompromitace. Vypocet zacina zakladnim skorem podle typu incidentu a pridava body za pocet neuspesnych pokusu, pocet zdrojovych IP adres, pocet cilovych uzivatelu, uspesne prihlaseni, kratky casovy rozsah a citlive ucty jako admin, root, backup, deploy, api nebo service.

Faktor	Priklad dopadu
Typ incidentu	Success after failures ma vyssi zaklad nez obycejny brute force
Pocet failed login	+4 za pokus, omezeno stropem
Vice IP nebo vice uzivatelu	Vyssi skore za sirsi rozsah utoku
Successful login	+12, protoze neuspechy mohly skoncit prunikem
Rychlost	+15 do 30 s, +10 do 120 s, +5 do 300 s
Citlivy ucet	+8 pro admin/root/backup/service apod.

Severity se odvozuje ze skore: LOW 0-29, MEDIUM 30-59, HIGH 60-84, CRITICAL 85-100.

6. Korelace do attack campaigns

Nad jednotlivymi incidenty je pridana korelacni vrstva AttackCampaign. Dva incidenty patri do stejne kampane, pokud jsou casove blizko a sdili alespon jednu IP adresu nebo uzivatelske jmeno. Tim se z vice samostatnych alertu stane prehlednejsi pohled na souvisici aktivitu.

Kampan ma vlastni ID, seznam incidentu, zdrojove IP adresy, cilove uzivatele, casovy rozsah, risk score a severity. Risk kampane vychazi z nejrizikovejsiho incidentu a pridava mensi bonusy za pocet souvisejicich incidentu, IP adres a uzivatelu.

7. Rozhrani a vystupy

- CLI prikazy: analyze, stats, dashboard, charts a app.
- TXT report je vhodny pro rychlou kontrolu v terminalu.
- JSON report obsahuje strukturovana data pro dalsi zpracovani.
- HTML dashboard a lokalni webova aplikace zobrazuji metriky, incidenty, kampane, profily IP, timeline a diagnostiku parseru.
- PNG grafy jsou volitelny vystup postaveny nad pandas, numpy a matplotlib.

8. Vysledky na dodanem vzorku

Metrika	Hodnota
Parsovane autentizacni udalosti	35
Neuspesna prihlaseni	31
Uspesna prihlaseni	4
Preskocene radky	2
Unikatni IP adresy	12
Unikatni uzivatele	13
Nalezene incidenty	9
Korelovane attack campaigns	2
Nejvyssi severity	CRITICAL

Ukazkovy log obsahuje nekolik ruznych scenaru: kratky brute force na admina ukonceny uspesnym loginem, enumeraci uzivatelu, distribuovany utok na backup, signal mozneho account takeover pro deploy a low-and-slow utok na service ucet.

9. Testovani a kontrola stylu

Projekt obsahuje pytest testy pro parser, ignorovani spatnych radku, detekcni pravidla, vypocet risk score, tvorbu incidentu, korelaci kampani, HTML dashboard, lokalni webovou aplikaci a grafy. Aktualni kontrola prosla s vysledkem 22/22 testu.

Kod byl zkontrolovan pomoci pycodestyle bez chyb. Pylint pri povolenych vyjimkach C0301 a C0103 podle doporuceni predmetu ohodnotil projekt 10.00/10.

10. Omezeni a dalsi rozvoj

Risk score je zamerne jednoducha a vysvetlitelna heuristika. Neni to strojove uceni ani forenzni dukaz. Pro realne nasazeni by bylo vhodne doplnit whitelist internich siti, konfiguraci pravidel z YAML/JSON, praci s vice log soubory, historicke baseline chovani uzivatelu a export do SIEM systemu.

Projekt je ale pripraveny k rozsireni, protoze parser, pravidla, risk, reporty i webove rozhrani jsou oddelene moduly.

11. Zdroje a poznamka k AI

Zdroje: PEP 8 Style Guide for Python Code, dokumentace Pythonu pro argparse, dataclasses, enum, ipaddress, json a pathlib, dokumentace pytest, numpy, pandas a matplotlib.

OpenAI ChatGPT/Codex byl pouzit pouze jako podpurny nastroj pro drobne navrhy formulaci, pripomenuti prikazu ke kontrole stylu a malou cast prvotniho navrhu weboveho rozhrani. Finalni struktura, implementace, testy, ladeni a vysledne upravy byly zkontrolovany autorem.